

State of Maine

Department of Administrative and Financial Services

Office of Information Technology

System and Communications Protection Procedures for Defense-in-Depth (SC-2, 4, 5, 20, 21, 22, 23, 28, and 39)

System and Communications Protection Procedures for Defense-in-Depth (SC-2, 4, 5, 20, 21, 22, 23, 28, and 39)

Table of Contents

1.0. Document Purpose 3

2.0. Scope 3

3.0. Procedure Conflict 3

4.0. Roles and Responsibilities 3

5.0. Management Commitment 3

6.0. Coordination Among Agency Entities 3

7.0. Compliance 3

8.0. Procedures 4

9.0. Document Details 11

10.0. Review 11

11.0. Records Management 11

12.0. Public Records Exceptions 11

13.0. Definitions 12

14.0. Abbreviations 13

System and Communications Protection Procedures for Defense-in-Depth (SC-2, 4, 5, 20, 21, 22, 23, 28, and 39)

1.0. Document Purpose

The purpose of this document is to define the State of Maine policy and procedures that are in place for defense-in-depth cybersecurity of State of Maine information assets (see Definitions). The State of Maine defense-in-depth focuses on requirements related to application partitioning, information in shared resources, denial-of-service protection, name/address resolution, session authenticity, information at rest, information system partitioning, and process isolation. This part of the security program is focused on protecting the confidentiality (see Definitions), integrity (see Definitions), and availability (see Definitions) of State information assets. This document corresponds to the System and Communications Protection Procedures for Defense-in-Depth (SC-2, 4, 5, 20, 21, 22, 23, 28, and 39) Control Family of National Institute of Standards and Technology (NIST) Special Publication 800-53 (Rev. 5).[1]

2.0. Scope

2.1. These procedures apply to State of Maine employees and contractors (collectively referred to as personnel in this document) with access to:

2.1.1. Executive Branch Agency information assets, irrespective of location; and

2.1.2. Information assets from other State government branches that use Executive Branch-managed services.

3.0. Procedure Conflict

If these procedures conflict with any law or union contract in effect, the terms of the existing law or contract prevail.

4.0. Roles and Responsibilities

Please refer to the System and Communications Protection Policy and Procedures (SC)[2] document for further information.

5.0. Management Commitment

The State of Maine is committed to following these procedures and the policy that it supports.

6.0. Coordination Among Agency Entities

Please refer to the System and Communications Protection Policy and Procedures (SC)[3] document for further information.

7.0. Compliance

---

[1] https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
[2] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SystemCommunicationsProtectionPolicy.pdf
[3] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SystemCommunicationsProtectionPolicy.pdf

7.1. For State of Maine employees, failure to comply with this document may result in progressive discipline, up to and including dismissal.

7.2. For State of Maine contractors and non-State of Maine personnel, failure to comply may result in the removal of the individual's ability to access and use State of Maine data and systems. Employers of contractors will be notified of any violations.

7.3. Personnel are also subject to any applicable penalties for statutory requirements compliance violations. Depending on the requirement and the nature of the violation, penalties could include fines and/or criminal charges.

8.0. Procedures

The following standards apply to and represent the baseline security controls and processes established to meet an acceptable level of protection for the State of Maine's information assets through defense-in-depth practices.

8.1. Controls Cross References

The following controls for the System and Communications Protection Policy and Procedures (SC) are published in separate policy and procedure documents:

8.1.1. System and Communications Protection Policy and Procedures (SC);[4]

8.1.2. System and Communications Protection Procedures for Encryption Mechanisms (SC-12, 13, and 17);[5] and

8.1.3. System and Communications Protection Procedures for Specific Technologies (SC-10, 15, 18, and 40)[6].

8.1.4. System and Communications Protection controls applicable exclusively to Federal Tax Information (FTI), including Voice over Internet Protocol (SC-19), are addressed in IRS Publication 1075–scoped documentation and are not implemented within the general System and Communications Protection procedures.

8.2. Application Partitioning (SC-2, (1))

8.2.1. Application partitioning ensures information systems separate user functionality (including user interface services) from information system management functionality.

8.2.2. OIT Information Asset Owners logically separate user functionality from system management functionality through access control mechanisms, including privileged account separation, role-based

[4] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SystemCommunicationsProtectionPolicy.pdf
[5] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SCEncryptionMechanismsProcedures.pdf
[6] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SCSpecificTechnologies.pdf

access control, and controlled privilege escalation processes, in accordance with the Access Control Policy and Procedures (AC)[7].

8.2.3. OIT Information Asset Owners ensure that administrative options are not available to non-privileged (see Definitions) users, including options that are greyed out, until user sessions are established with administrator privileges. See Access Control Procedures for Users (AC-2).[8]

8.2.3.1. Privileged access is granted only after users authenticate using standard user credentials and is explicitly authorized through enterprise access approval and ticketing workflows. Privileged access is logged and subject to audit.

8.2.4. OIT uses the following methods to separate user functionality from information system management functionality:

8.2.4.1. Active Directory (AD) permissions restrict a user's ability to access or start up an application.

8.2.4.2. Application user accounts are required for successful login.

8.2.4.3. Role-based access control (RBAC) (see Definitions) allows user access, as necessary, based on the user's role. Restrictions for RBAC are associated with data governed by federal entities and laws, such as the Internal Revenue Service, the U.S. Department of the Treasury, the Social Security Administration, and Health Insurance Portability and Accountability Act.

8.3. Information in Shared Resources (SC-4)

8.3.1. Information Asset Owners ensure that information systems prevent unauthorized and unintended transfer of information through shared system resources by enforcing residual information protection mechanisms. These mechanisms ensure that information produced by prior users, roles, or processes is not accessible to subsequent users, roles, or processes after shared resources are released or reassigned.

8.3.1.1. Shared system resources, including memory, storage, temporary files, buffers, and caches, are cleared, reinitialized, or otherwise sanitized prior to reuse.

8.3.1.2. Operating system, platform, or virtualization controls are configured to prevent residual data exposure between users, processes, or workloads when shared resources are reassigned.

[7] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/AccessControlPolicy.pdf
[8] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/AccessControlProceduresForUsers.pdf

8.3.1.3. Controls supporting residual information protection are applied consistently across multi-user systems and environments that employ shared computing resources.

8.4. Denial-of-Service Protection (SC-5)

8.4.1. The Office of Information Technology (OIT) implements technical and operational controls to protect against and limit the effects of denial-of-service (DoS) events that could impact the availability of State of Maine systems and services.

8.4.2. Denial-of-service protections address multiple event types, including volumetric attacks, protocol-based attacks, and application-layer attacks, through a combination of boundary protections, capacity management, redundancy, and monitoring.

8.4.3. Boundary protection mechanisms, including firewalls and web application protection services, are used to filter malicious traffic and prevent denial-of-service conditions from directly impacting internal systems. OIT Network Security prevents Denial-of-Service (DoS) attacks (see Definitions) against web assets using a Web Application Firewall (WAF) as a cloud reverse-proxy to conceal the Internet Protocol (IP) addresses of web servers. The WAF:

8.4.3.1. Filters malicious traffic before it reaches the web servers;

8.4.3.2. Leverages a global Content Delivery Network (see Definitions) for geographic redundancy; and

8.4.3.3. Provides distributed denial-of-service (DDoS) mitigation capabilities through upstream traffic filtering, scrubbing services, and scalable network protections.

8.4.4. Network capacity, bandwidth management, geographic distribution, and service redundancy are employed to reduce susceptibility to DoS events and to limit service degradation during attack conditions.

8.4.5. OIT employs network monitoring, telemetry, and analytics capabilities to detect anomalous traffic patterns indicative of denial-of-service activity and to support timely response and escalation.

8.4.6. Network security infrastructure is configured to fail securely under denial-of-service conditions to prevent unintended access or uncontrolled traffic flow.

8.4.7. Detection, response, coordination, and escalation procedures for denial-of-service events are defined within the Cyber Incident Response Plan[9] and supporting operational playbooks.

[9] http://inet.state.me.us/oit/policies/documents/IncidentResponsePlan.pdf

8.4.8. In the event of a DDoS alert or attack, OIT Network Operations or the Information Security Office will submit a report of the situation to Networkmaine. The University of Maine System, via Networkmaine, uses Akamai DDoS Attack Prevention. Upon detection and validation of a DDoS attack, Akamai DDoS Attack Prevention will have the traffic externally scrubbed.

8.5. Secure Name/Address Resolution (Authoritative Source) (SC-20)

8.5.1. OIT Network Security utilizes an Internet Protocol Address Manager (IPAM) administer authoritative Domain Name System (DNS) services that support data origin authentication and integrity verification artifacts.

8.5.1.1. The authoritative DNS infrastructure is deployed in a distributed architecture to improve resilience and availability during DNS-based attack conditions.

8.5.1.2. Administrative and synchronization communications between IPAM and authoritative DNS components are protected using secure network transport mechanisms.

8.5.2. Authoritative DNS services validate and respond to name/address resolution requests using centrally managed directory and configuration sources, as applicable.

8.5.3. The authoritative DNS service enables verification of a chain of trust among parent and child zones, where child zones support secure resolution services, when operating as part of a distributed, hierarchical namespace.

8.5.4. Administrative access to authoritative DNS and IPAM services is restricted, logged, and monitored. Detection and response to anomalous or malicious name resolution activity is supported through centralized logging, SIEM correlation, network monitoring, and SOC-integrated incident response.

8.6. Secure Name/Address Resolution (Recursive or Caching Resolver) (SC-21)

8.6.1. OIT Network Security utilizes DNS servers, which are Authoritative for the Maine.Gov domain that securely provides DNS for zones delegated by the DotGov registrar (see Definitions).

8.6.2. OIT Network Security utilizes secure recursive or caching DNS resolvers to resolve external domain names for local clients. These resolvers provide response integrity protections and validation capabilities, or clients rely on authenticated channels to resolvers that perform such validation on their behalf.

8.6.3. OIT Network Security utilizes access control lists, populated by other DNS server names, which allow access only from a specified list of

outside DNS servers. This method prevents unauthorized use of DNS infrastructure as an open resolver for recursive queries (see Definitions).

8.7. Architecture and Provisioning for Name/Address Resolution Service (SC-22)

8.7.1. OIT Network Security employs a distributed DNS architecture administered through IPAM, with separation of internal and external DNS service roles, to ensure redundancy and fault tolerance.

8.7.2. Authoritative DNS infrastructure supporting name and address resolution services is deployed across the State of Maine's two principal datacenters to reduce single points of failure and enhance service availability.

8.7.3. Authoritative DNS servers supporting external resolution requests are deployed in a primary and secondary configuration, with role-based access controls restricting client access based on internal or external service roles.

8.8. Session Authenticity (SC-23, (1), (5))

8.8.1. OIT Network Security implements session-level mechanisms to protect the authenticity and integrity of communications and to mitigate session hijacking, man-in-the-middle attacks, and the insertion of false information into active sessions.

8.8.2. The OIT Computing Infrastructure and Services team, in collaboration with the Unix, Oracle Database, and Middleware teams, implements session authenticity mechanisms through the use of secure session establishment mechanisms, including cryptographically protected communication protocols and certificate-based trust relationships.

8.8.3. Invalidate Session Identifiers at Logout (SC-23(1))

8.8.3.1. OIT Network Security implements automatic session lockouts to systems and applications, once a user logs out of a workstation, through mechanisms such as a Failsafe Central Management System, which is a cyber guard for both internal and external session-level protection. In addition, OIT-configured applications and services invalidate or terminate associated session identifiers upon logout or session termination to prevent reuse of previously valid session identifiers.

8.8.4. Allowed Certificate Authorities (SC-23(5))

8.8.4.1. Public Key Infrastructure (PKI) Certificate Authorities (CAs) used to establish secure sessions that are approved, managed, and validated through OIT-managed certificate services, including Microsoft Active Directory Certificate

Services and certificate services supporting Oracle and Red Hat Enterprise Linux environments, as applicable.

8.8.4.2. OIT maintains a process to strictly control PKI-based authentication. See the Identification and Authentication Policy and Procedures (IA-1)[10] (Intranet only).

8.8.4.3. The following PKI Certificates are utilized by OIT to support authenticated and protected session establishment:

8.8.4.3.1. Entrust provides CA services supporting authenticated external electronic communications, including digital signing and encryption.

8.8.4.3.2. SOM Root CA provides internal-only CA services supporting authenticated sessions for servers, network devices, and internal services.

8.8.4.4. In general, exportation of the PKI private key is prohibited. See 8.4.6.1 of Configuration Management Policy[11] for permitted use cases.

8.9. Protection of Information at Rest (SC-28)

8.9.1. The OIT Computing Infrastructure and Services team, in collaboration with the OIT Oracle Database team, protects the confidentiality and integrity of data at rest (see Definitions) through user privileges, database encryption, file-server encryption, and storage mechanisms.

8.9.2. OIT has adopted the Traffic Light Protocol (TLP) as the method for classifying data (see the Data Classification Policy[12]). All data/information identified as TLP: Amber, TLP: Amber+Strict, or TLP: Red are encrypted at rest using AES 256 encryption to prevent unauthorized disclosures and modifications.

8.9.3. Virtual database storage is employed by default through a relational database management system. This system hosts multiple levels of encryption to protect TLP: Amber, TLP: Amber+Strict, and TLP: Red data at rest.

8.9.3.1. Cryptographic keys used to protect information at rest are stored and managed using protected key storage mechanisms appropriate to the platform, including hardware-backed or system-protected key stores where supported.

[10] https://inet.state.me.us/oit/policies/documents/IdentificationAuthenticationPolicy.pdf
[11] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ConfigurationManagementPolicy.pdf
[12] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/DataClassificationPolicy.pdf

8.9.4. All offline storage network shares for legacy assets containing TLP: Amber, TLP:Amber+Strict, or TLP: Red data are secured and backed up in alignment with the Media Protection Policy (MP-1)[13] (Intranet only). The legacy Commvault system is used to maintain and store tape backups offsite at Iron Mountain.

8.9.5. Agencies, in consultation with OIT, support the protection of information at rest by enforcing approved authorizations, separation of duties, and the principle of least privilege, in accordance with the Access Control Procedures for Users[14].

8.9.6. Agencies, in consultation with OIT, support the integrity of information at rest by employing integrity verification tools to identify unauthorized changes to stored software and information, in accordance with System and Information Integrity Policy and Procedures (SI-1)[15].

8.10. **Process Isolation (SC-39)**

8.10.1. The OIT Computing Infrastructure and Services team, in collaboration with the OIT Oracle Database team, maintains a separate execution domain for each executing process.

8.10.2. Separation for Process Isolation: The OIT Computing Infrastructure and Services team, in collaboration with the OIT Linux team, utilizes Linux Kernel Features, Namespaces, Control Groups (Cgroups) (see Definitions), and Capabilities to maintain separate execution domains as well as Microsoft Distribution Points (DP) and Data Execution Prevention (DEP). The Microsoft Data Execution Prevention (DEP) policy is enabled by default in Windows 10 and Microsoft Server 2016 and later.

8.10.2.1. Microsoft DEP is used during process isolation as well as to perform additional checks on memory to prevent malicious code from running on the system.

8.10.2.2. Namespaces maintain a separate execution domain that is only visible to other Namespace processes.

8.10.2.3. Cgroups are provided through a pseudo-filesystem and implemented in the core Cgroups kernel code, while resource tracking, and limits are implemented in a set of per-resource-type subsystems such as memory and the central processing unit (CPU).

[13] https://inet.state.me.us/oit/policies/documents/MediaProtectionPolicy.pdf
[14] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/AccessControlProceduresForUsers.pdf
[15] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SystemInformationIntegrityPolicy.pdf

8.10.2.4. Capabilities is a per-thread attribute that divides the privileges associated with a privileged user (see Definitions) into distinct units to independently enable and disable domains.

8.10.2.5. Thread Isolation:

8.10.2.5.1. Linux Kernel Control Groups or Cgroups and Capabilities are used by OIT for thread isolation.

8.10.2.5.2. Microsoft DEP facilitates the control of process creep.

9.0. Document Details

9.1. Initial Issue Date: January 30, 2024

9.2. Latest Revision Date: January 16, 2026

9.3. Point of Contact: PolicyTeam.OIT@Maine.Gov

9.4. Approved By: Chief Information Officer, OIT

9.5. Legal Citation: Title 5, Chapter 163: Office of Information Technology[16]

9.6. Waiver Process: Waiver Policy[17]

9.7. Distribution: Internet[18]

10.0. Review

This document will be reviewed triennially, and when substantive changes are made to Policies, Procedures, or other authoritative regulations affecting this document.

11.0. Records Management

OIT security policies, plans, and procedures fall under the *Major Administrative Policies and Procedures* and *Internal Control Policies and Directives* records management categories. They will be retained for a minimum of six years after withdrawal or replacement and then destroyed in accordance with guidance[19] provided by Maine State Archives. Retention of these documents will be subject to any future State Archives General Schedule revisions that cover these categories.

12.0. Public Records Exceptions

Under the Maine Freedom of Access Act (FOAA),[20] certain public records exceptions may limit disclosure of agency records related to information technology infrastructure and systems, as well as security plans, procedures, or

[16] https://legislature.maine.gov/statutes/5/title5ch163sec0.html
[17] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf
[18] https://www.maine.gov/oit/policies-standards
[19] https://www.maine.gov/sos/arc/records/state/GS1Administrative.pdf
[20] https://legislature.maine.gov/statutes/1/title1sec402.html

risk assessments. Information contained in these records may be disclosed to the Maine State Legislature or, in the case of a political or administrative subdivision, to municipal officials or board members under conditions that protect the information from further disclosure. Any aggrieved person seeking relief for an alleged violation of the FOAA may bring suit in any Superior Court in the State.

13.0. Definitions

13.1. Advanced Encryption Standard (AES) 256: A U.S. Government-approved cryptographic algorithm that can be used to protect electronic data. The AES algorithm is a symmetric block cipher that can encrypt (encipher) and decrypt (decipher) information. Source NIST.21

13.2. Chain of Trust: A certain level of trust in supply chain interactions so that each participant in the consumer-provider relationship provides adequate protection for its component products, systems, and services. Source NIST.22

13.3. Content Delivery Network: A network of servers that is geographically dispersed to enable faster web performance by locating copies of web content closer to users or facilitating delivery of dynamic content (e.g., live video feeds).

13.4. Control Group (Cgroups): A Linux kernel feature that limits, accounts for, and isolates the resource usage (CPU, memory, disk I/O, network, etc.) of a collection of processes.

13.5. Data at Rest: The state of information when it is located on storage devices as specific components of information systems.

13.6. Denial of Service (DoS) Attack: The prevention of authorized access to resources or the delaying of time-critical operations. (Time-critical may be milliseconds or it may be hours, depending upon the service provided). Source NIST.[23]

13.7. Distributed Denial of Service (DDoS) Attack: A denial of service technique that uses numerous hosts to perform the attack. Source NIST.24

13.8. DotGov Registrar: The domain name '.gov' is a sponsored top-level domain (sTLD) in the Domain Name System of the internet. DotGov is derived from the word government, indicating its restricted use by government entities. The TLD is administered by the Cybersecurity and Infrastructure Security Agency (CISA), which is a component of the United States Department of Homeland Security.

[21] https://csrc.nist.gov/glossary/term/advanced_encryption_standard
[22] https://csrc.nist.gov/glossary/term/chain_of_trust
[23] https://csrc.nist.gov/glossary/term/denial_of_service
[24] https://csrc.nist.gov/glossary/term/distributed_denial_of_service

13.9. Endpoints: End-user devices such as desktops, laptops, and mobile devices. Endpoints serve as points of access to an enterprise network and create points of entry that can be exploited by malicious actors.

13.10. Federal Information Processing Standard (FIPS): Publicly announced standards for use in computer systems by non-military American government agencies and government contractors.

13.11. Information Asset: A discrete, identifiable piece of information technology, including hardware, software, firmware, systems, services, and related technology assets used to execute work on behalf of OIT or another State Agency.

13.12. Non-Privileged User: A user who is unauthorized to perform security-relevant functions within various user accounts and processes.

13.13. Manipulator-in-the-Middle Attack: An attacker positioned between two communicating parties in order to intercept and/or alter data traveling between them. For example, in the context of authentication, the attacker would be positioned between a claimant and a verifier during authenticator binding.

13.14. Privileged User: A user who is granted rights that go beyond those of a typical business user to manage and maintain IT systems. Usually, these rights include administrative access to networks and devices and are separate from users' administrative access to their own workstations.

13.15. Recursive Query: A DNS query in which a resolver contacts a name server to perform a name lookup. The name server then returns a result or an error. The name server cannot refer the client to a different name server, but it can forward the query directly to another name server if it has a forwarder configured.

13.16. Role-Based Access Control (RBAC): Access control based on user roles (i.e., a collection of access authorizations a user receives based on an explicit or implicit assumption of a given role). Role permissions may be inherited through a role hierarchy and typically reflect the permissions needed to perform defined functions within an organization. A given role may apply to a single individual or to several individuals. Source NIST. [25]

14.0. Abbreviations

14.1. AD: Active Directory

14.2. AES: Advanced Encryption Standard

14.3. CA: Certificate Authority

14.4. CGroups: Control Groups

[25] https://csrc.nist.gov/glossary/term/role_based_access_control

14.5.	CISA:	Cybersecurity and Infrastructure Security Agency
14.6.	CPU:	Central Processing Unit
14.7.	DDoS:	Distributed Denial of Service
14.8.	DEP:	Data Execution Prevention
14.9.	DNS:	Domain Name System
14.10.	DoS:	Denial of Service
14.11.	DP:	[Microsoft] Distribution Point
14.12.	FIPS:	Federal Information Processing Standard
14.13.	FOAA:	[Maine] Freedom of Information Act
14.14.	IP:	Internet Protocol
14.15.	IPAM:	Internet Protocol Address Manager
14.16.	IT:	Information Technology
14.17.	NIST:	National Institute of Standards and Technology
14.18.	OIT:	Office of Information Technology
14.19.	PKI:	Public Key Infrastructure
14.20.	RBAC:	Role-Based Access Control
14.21.	SC:	System and Communication Protection
14.22.	SOM:	State of Maine
14.23.	sTLD	Sponsored Top-Level Domain
14.24.	TLP:	Traffic Light Protocol
14.25.	WAF:	Web Application Firewall